

Collaborative Discussion 2 Summary Post

Abinel Madzivire

The discussion has reinforced my view that CVSS remains useful as a common framework for communicating technical vulnerability severity, but it should not be treated as an objective or complete measure of organisational risk. Wunder *et al.* (2024) demonstrate that considerable variation can occur when practitioners interpret CVSS metrics, which challenges the assumption that numerical scores are consistently reproducible.

The peer responses have also developed my understanding of the limitations of EPSS. Janet Karani highlighted the importance of combining exploitation probability with asset criticality, business impact and threat intelligence. This strengthens the argument that vulnerability prioritisation should be based on organisational context rather than on a single numerical score.

Kaona Hoxha further raised an important concern regarding the predictive nature of EPSS. Because EPSS depends on observable exploitation data and other indicators, low scores may sometimes result from limited evidence rather than genuinely low risk. Newly disclosed vulnerabilities and vulnerabilities affecting specialist systems may therefore require additional judgement. This aligns with Aven and Thekdi's (2025) argument that risk assessments should consider the strength and uncertainty of the knowledge supporting decisions.

Consequently, I would refine my original position. Rather than replacing CVSS entirely with EPSS, organisations should combine CVSS severity, EPSS exploitation probability, asset criticality, business consequences and current threat intelligence.

Such a layered approach provides a more defensible and context-sensitive basis for vulnerability prioritisation.

References

Aven, T. and Thekdi, S. (2025) *Risk Science*. 3rd edn. Abingdon: Routledge.

Jacobs, J., Romanosky, S., Edwards, B., Adjerid, I. and Roytman, M. (2021) 'Exploit prediction scoring system (EPSS)', *Digital Threats: Research and Practice*, 2(3), pp. 1–17. doi: 10.1145/3436242.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) 'Shedding light on CVSS scoring inconsistencies: A user-centric study on evaluating widespread security vulnerabilities', *2024 IEEE Symposium on Security and Privacy (SP)*, pp. 1102–1121. doi: 10.1109/SP54263.2024.00058.